CRYPTOGRAPHY AND KEY MANAGEMENT POLICY

POL-018 | Policy | Part of the Information Management Framework

Document ID: POL-018
Version: 1.0 — DRAFT
Classification: Internal Use
Owner: CISO
Co-Owner: CIO
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Cryptography and Key Management Policy
Document ID	POL-018
Version	1.0 — DRAFT
Parent Framework	IMF-001 — Information Management Framework
Related Documents	POL-001 (Data Classification), POL-008 (Access Control), POL-009 (PAM), POL-014 (Audit Trail), POL-016 (Backup Management), POL-017 (Vulnerability Management), SOP-018 (Cryptography Process), EXC-001, RACI-001
Owner	CISO
Co-Owner	CIO
Approved By	[Approver Name and Title]
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose and Scope

This policy establishes the mandatory requirements for the use of cryptography at [Company Name] — covering approved algorithms, key lifecycle management (generation, storage, rotation, escrow, and destruction), certificate management, and HSM governance. Cryptography is a foundational control that underpins encryption at rest (POL-016), encryption in transit, PAM secrets management (POL-009), GxP audit trail integrity (POL-014), and the access control mechanisms in POL-008. Without a governing framework, each of these documents imposes encryption requirements that may be implemented inconsistently, use deprecated algorithms, or leave encryption keys inadequately protected.

This policy applies to all cryptographic implementations at [Company Name]: data encryption at rest and in transit, digital signatures, certificate-based authentication, password hashing, secrets management (API keys, service account credentials, tokens), and any cryptographic function in GxP validated systems. It applies to all system tiers and all data classifications.

> **IMPORTANT:** A cryptographic control is only as strong as its key management. AES-256 encryption with a key stored in a plaintext configuration file on the same server is not encryption — it is the appearance of encryption. This policy treats key management as the primary cryptographic risk, not algorithm selection.

2. Approved Cryptographic Algorithms

The following algorithms are approved for use at [Company Name]. Unapproved algorithms must not be introduced without a formal exception (EXC-001) reviewed by Information Security and approved by CISO. Use of prohibited algorithms on any in-scope system is a policy violation regardless of whether the data being protected is currently classified as sensitive.

2.1 Symmetric Encryption

Algorithm	Key Length	Approved Use	Notes
AES-GCM	256-bit	Preferred. Data at rest (all tiers), data in transit where TLS is not applicable, backup encryption, full-disk encryption.	Authenticated encryption — provides both confidentiality and integrity. Preferred over AES-CBC.
AES-CBC	256-bit	Acceptable. Legacy system compatibility where AES-GCM is not supported.	Must use a random IV per encryption operation. Not preferred for new implementations.

Algorithm	Key Length	Approved Use	Notes
AES-128	128-bit	Acceptable for Tier 3/4 data at rest only. Not approved for GxP, Tier 1, or Tier 2.	128-bit provides adequate security for low-sensitivity data but is not future-proof. New implementations should use 256-bit.
3DES / DES / RC4 / Blowfish	Any	PROHIBITED.	Deprecated. Not approved under any circumstances. Systems using these algorithms must be remediated as a High vulnerability (POL-017).

2.2 Asymmetric Encryption and Key Exchange

Algorithm	Key Length / Curve	Approved Use	Notes
RSA	4096-bit minimum	Key exchange, digital signatures, certificate keys.	2048-bit RSA is acceptable only for legacy compatibility — new implementations must use 4096-bit minimum or ECC equivalent.
ECDSA / ECDH	P-256 (NIST), P-384 preferred	Digital signatures, key exchange, TLS certificates.	P-384 preferred for Tier 1 and GxP. P-256 acceptable for Tier 2 and below.
Ed25519	256-bit	SSH keys, digital signatures.	Preferred for SSH key pairs (SOP-009 PAM managed).
RSA < 2048 / DSA / DH < 2048	Any	PROHIBITED.	Deprecated. Systems using these must be remediated as a High vulnerability (POL-017).

2.3 Hashing and Message Authentication

Algorithm	Approved Use	Notes
SHA-256	Integrity verification, digital signatures, certificate fingerprints.	Minimum for all uses.
SHA-384 / SHA-512	Preferred for Tier 1, GxP, and SOX ITGC integrity functions.	Use where performance permits.
HMAC-SHA-256	Message authentication codes, API request signing, audit trail integrity tokens.	
bcrypt / scrypt / Argon2	Password hashing only.	Minimum cost factor: bcrypt cost 12; scrypt N=16384; Argon2id with recommended parameters. Never store

Algorithm	Approved Use	Notes
		passwords as plaintext or reversible encrypted values.
SHA-1 / MD5	PROHIBITED except for non-security-relevant checksums (file transfer verification only, not integrity assurance).	SHA-1 and MD5 are cryptographically broken for integrity or authentication purposes. Any use for security functions is a policy violation.

2.4 Transport Layer Security

Protocol	Status	Notes
TLS 1.3	Preferred for all new implementations.	Mandatory for Tier 1 and GxP external-facing endpoints.
TLS 1.2	Acceptable. Required minimum for all in-scope systems.	Cipher suite restrictions: only AEAD ciphers (AES-GCM). No RC4, no 3DES, no CBC in TLS 1.2 where TLS 1.3 is available.
TLS 1.1 / TLS 1.0 / SSL	PROHIBITED.	Systems still serving TLS 1.1, 1.0, or SSL are a High vulnerability (POL-017).
Self-signed certificates	Permitted only in isolated development/test environments. Not permitted in production.	Production systems must use certificates issued by the [Company Name] CA or an approved public CA.

3. Key Management Lifecycle

The cryptographic key lifecycle has six phases: generation, distribution, storage, use, rotation, and destruction. Each phase has mandatory requirements. A failure in any single phase can nullify the security provided by the strongest algorithm.

3.1 Key Generation

Requirement	Standard
Entropy source	All cryptographic keys must be generated using a cryptographically secure random number generator (CSPRNG). Key generation on HSM hardware is preferred — HSMs provide hardware entropy sources that are preferable to software CSPRNGs.

Requirement	Standard
Generation environment	Symmetric keys for Tier 1 and GxP systems: generated on the HSM. Keys must not be generated in environments where they may be logged, captured in debug output, or stored in volatile memory accessible to untrusted processes.
Key length	Per Section 2. Key lengths below the approved minimums must not be used regardless of algorithm.
Documentation	Every key must be documented in the Key Register (SOP-018): key ID, key type, algorithm, length, owner system, generation date, rotation schedule, and custodians.

3.2 Key Storage

Key Type	Storage Requirement
Tier 1 and GxP system encryption keys	Hardware Security Module (HSM). Cloud HSM (AWS CloudHSM, Azure Dedicated HSM, or equivalent) or on-premises FIPS 140-2 Level 3 HSM. Keys must not be exported from the HSM in plaintext under any circumstances.
Tier 2 system encryption keys	HSM preferred. Software-based key management service (AWS KMS, Azure Key Vault, GCP Cloud KMS) acceptable where HSM is not feasible — access logging enabled, key material never exported to application memory.
Tier 3 / Tier 4 system encryption keys	Approved key management service. Never hardcoded in source code, configuration files, environment variables in plaintext, or version control systems.
Backup encryption keys	HSM. Separate HSM or HSM partition from the primary system encryption keys — a compromise of the primary system must not simultaneously expose the backup encryption keys (POL-016 requirement).
PAM-managed secrets (API keys, service account credentials, tokens)	PAM platform (SOP-009). Not stored in any other location.
SSH private keys	HSM or hardware security key (FIDO2). Where software storage is unavoidable: encrypted key file with strong passphrase stored in PAM.
Code signing keys	HSM. Access restricted to the build pipeline service account only. Any human access to code signing keys is a security incident.

3.3 Key Access Control

Access to cryptographic keys is governed by the principle of separation of duties and least privilege. The following restrictions apply across all key types:

- No single individual may have the ability to both access encrypted data and access the key protecting it — except where operationally unavoidable (documented exception via EXC-001).
- Access to HSM administration requires at least two-person integrity — no individual can make administrative HSM changes unilaterally. HSM administrator accounts are subject to PAM controls (SOP-009).
- Key custodianship — the named individuals or roles with access to a specific key — is documented in the Key Register. Key custodian changes are change-managed (SOP-007) and require CISO notification for Tier 1 and GxP keys.
- All key access events are logged: key usage, key export requests (which should never be approved for Tier 1/GxP), key administration, and HSM access. Logs forwarded to SIEM per POL-014.
- Key access by Information Security for investigation purposes follows the same break-glass procedure as PAM break-glass access (SOP-009) — witnessed, logged, and reviewed within 48 hours.

3.4 Key Rotation

Key Type	Rotation Frequency	Trigger for Immediate Rotation
Tier 1 and GxP encryption keys	Annual minimum.	Suspected or confirmed compromise; personnel change in key custodian; HSM migration; security incident on the system the key protects.
Tier 2 encryption keys	Annual minimum.	Suspected compromise; personnel change in key custodian.
Tier 3 / Tier 4 encryption keys	Every 2 years minimum.	Suspected compromise.
Backup encryption keys	Annual minimum, timed to coincide with annual backup infrastructure review (POL-016).	Suspected compromise; ransomware incident; personnel change in key custodian (CIO/Data Custodian IT).
TLS / SSL certificates	Per certificate expiry schedule — see Section 4. Certificates must be renewed before expiry.	Certificate key compromise; CA compromise; certificate misissuance.
SSH key pairs	Annual rotation for service accounts. Annual review for user keys.	User departure; suspected compromise.
Code signing keys	Annual minimum.	Any suspected compromise. Immediate revocation and re-signing of affected artefacts.
Symmetric data encryption keys (at-rest, long-lived)	Annual minimum. Key rotation must be	Suspected compromise; personnel change.

Key Type	Rotation Frequency	Trigger for Immediate Rotation
	accompanied by re-encryption of data under the new key, or a key wrapping scheme where the master key rotation is sufficient.	

3.5 Key Destruction

Key destruction is the permanent, irrecoverable removal of a cryptographic key and all copies of it. Key destruction renders any data protected only by that key unrecoverable — it is the cryptographic equivalent of data deletion. Destruction must be treated with the same care as key creation.

Requirement	Standard
When destruction is required	At end of key lifecycle (key has been superseded by rotation and all data has been re-encrypted under the new key). On decommission of the system the key protects. On confirmed key compromise (destroy and replace immediately).
Destruction method — HSM keys	HSM key deletion function. The HSM generates a destruction record. Where an HSM is decommissioned, the HSM is zeroised per manufacturer specification before disposal.
Destruction method — software keys	NIST SP 800-57 compliant overwriting of key material in memory and on storage. For cloud KMS: key deletion API with confirmation that the key is scheduled for permanent deletion per the cloud provider's key deletion process.
Verification	Destruction verified: attempt to use the destroyed key confirms it is irrecoverable. Verification documented in the Key Register.
GxP systems	Key destruction for GxP systems is a change under SOP-007 requiring Compliance / QA notification. If the key protected GxP audit trail data, destruction must not precede the end of the audit trail retention period (POL-002/POL-014).
Documentation	Key destruction event logged in the Key Register with: date, key ID, reason, method, confirming individual, and witness (for Tier 1 and GxP keys).

4. Certificate Management

Certificate expiry is one of the most common and preventable causes of system outages and security incidents. A TLS certificate expiry on an internet-facing system is a service disruption. A

certificate expiry on an internal authentication system can be a complete outage. Certificate management is a continuous operational obligation, not a one-time configuration activity.

Requirement	Standard
Certificate inventory	A certificate inventory is maintained in the Key Register (SOP-018): every certificate in use on in-scope systems, its subject, issuing CA, expiry date, owning system, and renewal owner. The inventory is automatically populated from certificate discovery scanning (Section 5 of SOP-018) and manually supplemented for certificates not discoverable by scan.
Certificate authority	Production certificates: issued by the [Company Name] internal PKI CA (for internal services) or an approved public CA (DigiCert, Sectigo, or equivalent — approved list maintained by Information Security). Self-signed certificates are prohibited in production.
Certificate validity period	Maximum 1-year validity for new certificates. Certificates with validity periods greater than 1 year issued before industry standards changed: flagged in the certificate inventory and replaced at next renewal.
Renewal timeline	Renewal process initiated at 60 days before expiry for Tier 1 and GxP systems. At 30 days before expiry for all other systems. Automated expiry alerting configured at 90 days, 60 days, 30 days, and 14 days before expiry.
Certificate key strength	RSA: 4096-bit minimum. ECDSA: P-384 preferred, P-256 acceptable. Certificate key strength must meet Section 2.2 requirements.
Wildcard certificates	Permitted for subdomains of a single domain where operationally justified. Not permitted for Tier 1 or GxP system certificates — each system must have its own certificate to limit the blast radius of a certificate compromise.
Certificate revocation	Where a certificate key is suspected compromised: immediate revocation via CA revocation process. Information Security notified. Replacement certificate issued and deployed. SOP-012 incident assessed (a compromised certificate may indicate a broader compromise of the system or PKI).
GxP systems	Certificate replacement on a GxP system is a Change under SOP-007. VIA required if the certificate is part of the validated configuration. Compliance / QA notified.

5. GxP Cryptographic Controls

Cryptographic controls on GxP systems are validated parameters. The algorithm, key length, and key management configuration documented in the System Description (SOP-006 VMF Section 3) are part of the validated state. Any change to these parameters is a Change under SOP-007 requiring a Validation Impact Assessment.

GxP Requirement	Standard
Algorithm documentation	The cryptographic algorithm, key length, and mode of operation for each encrypted component of a GxP system are documented in the IQ checklist and the System Description. 'Encryption enabled' is insufficient — the specific algorithm must be recorded.
Algorithm deprecation	When an algorithm used in a GxP system is identified as deprecated (moved from Approved to Acceptable or Prohibited in Section 2), Information Security notifies Compliance / QA. Algorithm upgrade is scheduled as a Normal Change with VIA. Deprecated algorithm on a GxP system is a Medium vulnerability (POL-017) that escalates to High if the algorithm is Prohibited.
Audit trail cryptographic integrity	GxP audit trail integrity tokens (hash-chain or HMAC per SOP-014) must use SHA-256 minimum. The integrity verification key is stored in the HSM and rotated annually. Key rotation for audit trail integrity requires re-generation of integrity tokens for existing records — process governed by SOP-014 and SOP-007.
Electronic signature cryptography	21 CFR Part 11 electronic signatures implemented using asymmetric cryptography must use RSA-4096 or ECDSA P-384 minimum. Signature verification keys managed in HSM. Signature algorithm documented in validation documentation.
Validated state and key rotation	Annual key rotation for GxP system encryption keys is a Standard Change in SOP-007 — it does not require a full VIA if the rotation procedure is included in the validated operational procedures and the algorithm does not change. A change to the algorithm or key length requires a VIA.

6. Cryptographic Exceptions

Where a system cannot meet the cryptographic requirements of this policy — typically legacy systems where algorithm upgrades require vendor involvement or GxP revalidation — a formal exception is required via EXC-001. The following constraints apply to cryptographic exceptions:

Exception Type	Approval	Maximum Duration	Mandatory Conditions
Approved algorithm at below-minimum key length (e.g., RSA-2048 where 4096 is required)	CISO	12 months, renewable once	Compensating controls. Upgrade roadmap with milestones. IS Risk Register entry. Vulnerability register entry (Medium).
Acceptable algorithm where Preferred is required (e.g., AES-CBC instead of AES-	Information Security Manager	12 months	Documented technical reason. Migration plan.

Exception Type	Approval	Maximum Duration	Mandatory Conditions
GCM)			
Prohibited algorithm — legacy system, no vendor upgrade available	CISO + CIO + Board notification for Tier 1 / GxP	6 months maximum, requires formal risk acceptance at renewal	Network isolation required. No internet exposure. Compensating controls. IS Risk Register entry. Funded replacement roadmap.
Self-signed certificate in production — transitional	CISO	30 days only	During certificate authority migration or emergency only.

NOTE: AES-256 encryption below the minimum key length cannot be approved — see Section 2.1. The mandatory minimum is non-waivable. A system that cannot support AES-256 must be isolated and replaced.

7. Related Documents

Document ID	Title	Relationship
SOP-018	Cryptography and Key Management Process	Operationalises this policy — key lifecycle procedures, Key Register, certificate inventory management, HSM administration, algorithm deprecation process
POL-009	PAM Policy	Secrets (API keys, service account credentials) stored in PAM platform per SOP-009; PAM platform itself protected by HSM-stored credentials
POL-014	Audit Trail Policy	GxP audit trail integrity tokens use HMAC-SHA-256; integrity keys in HSM; key rotation process governed jointly by SOP-014 and this policy
POL-016	Backup Management Policy	Backup encryption keys in HSM; separate key partition from primary system keys; annual rotation timed to backup programme review
POL-017	Vulnerability Management Policy	Deprecated or prohibited algorithms on in-scope systems are vulnerabilities — Medium (Acceptable → Prohibited) or High (currently Prohibited). CVSS supplemented by context.

Document ID	Title	Relationship
POL-001	Data Classification Policy	Data classification determines minimum encryption standard — Restricted data requires AES-256; less sensitive data has minimum requirements per this policy
POL-008	Access Control Policy	MFA implementations use TOTP, FIDO2, and push notification — all cryptographic mechanisms governed by this policy
EXC-001	Exception Management	All cryptographic exceptions governed by EXC-001 subject to Section 6 constraints
RACI-001	Roles, Responsibilities and Authorities	Accountability for cryptographic controls

— End of Document —

POL-018 v1.0 DRAFT | [Company Name] | INTERNAL USE